

GSG-02

Risk Assessment Checklist

52 Controls Across 8 Security Domains

A structured checklist for conducting an internal security risk review. Score each control YES, PARTIAL, or NO. Use your results to identify gaps, assign ownership, and prioritize remediation.

// HOW TO USE

For each control, mark **YES** (fully implemented), **PARTIAL** (partially in place), or **NO** (not implemented). Add notes for context or evidence. At the end of each section, record your score (YES=2, PARTIAL=1, NO=0) in the Score Summary.

Rating	Points	Meaning
YES	2	Control fully implemented and documented
PARTIAL	1	Control partially implemented or inconsistently applied
NO	0	Control not in place

// SCORE SUMMARY

Domain	Score	/ Max	Rating
Domain 01 — Physical Security	_____	/ 12	_____
Domain 02 — Access Controls	_____	/ 14	_____
Domain 03 — Network Defenses	_____	/ 14	_____
Domain 04 — Data Protection	_____	/ 14	_____
Domain 05 — Incident Response	_____	/ 12	_____
Domain 06 — Vendor Risk	_____	/ 12	_____
Domain 07 — Security Awareness	_____	/ 14	_____
Domain 08 — Cloud and Remote Work	_____	/ 12	_____
TOTAL	_____	/ 104	_____

75-100% Strong Foundation 50-74% Moderate Risk 25-49% Elevated Risk 0-24% Critical Exposure

DOMAIN 01 Physical Security		MAX 12 pts			
ID	Control	YES	PARTIAL	NO	Notes
D01.01	Are server rooms, network closets, and IT equipment secured with locks limiting access to authorized personnel only?	☐	☐	☐	
D01.02	Is a visitor log or access record maintained for sensitive areas such as server rooms?	☐	☐	☐	
D01.03	Are workstations and laptops secured when unattended through locked screen policy, cable locks, or secured storage?	☐	☐	☐	
D01.04	Do you have surveillance cameras or physical access monitoring at entry points to your facility?	☐	☐	☐	
D01.05	Are backup media, portable drives, and sensitive printed documents physically secured in a locked location?	☐	☐	☐	

D01.06	Is there a formal process for issuing and revoking physical access when employees join or leave?	☐	☐	☐	
DOMAIN 01 SCORE _____ / 12 Rating: _____					

DOMAIN 02 Access Controls		MAX 14 pts			
ID	Control	YES	PARTIAL	NO	Notes
D02.01	Does every user have a unique account? Are shared or generic accounts such as admin or office prohibited?	☐	☐	☐	
D02.02	Is multi-factor authentication (MFA) enabled for email, cloud services, VPN, and remote access?	☐	☐	☐	
D02.03	Do employees have access only to the systems and data they need for their job (principle of least privilege)?	☐	☐	☐	
D02.04	Are administrative or privileged accounts separate from standard user accounts?	☐	☐	☐	
D02.05	Is there a formal process for provisioning and deprovisioning accounts when staff join, transfer, or leave?	☐	☐	☐	
D02.06	Are user access rights reviewed at least annually to ensure they remain appropriate to the current role?	☐	☐	☐	
D02.07	Is there a documented password policy enforcing minimum length, complexity, and prohibiting reuse?	☐	☐	☐	
DOMAIN 02 SCORE _____ / 14 Rating: _____					

DOMAIN 03 Network Defenses		MAX 14 pts			
ID	Control	YES	PARTIAL	NO	Notes
D03.01	Is your network protected by a business-grade firewall with documented rules reviewed at least annually?	☐	☐	☐	
D03.02	Is your guest Wi-Fi on a separate network segment from business systems and internal resources?	☐	☐	☐	
D03.03	Are all network devices running current firmware and using non-default credentials?	☐	☐	☐	
D03.04	Do you have network monitoring or logging in place to detect unusual traffic or unauthorized connections?	☐	☐	☐	
D03.05	Is remote access limited to approved VPN or zero-trust methods with no open RDP exposed to the internet?	☐	☐	☐	

D03.06	Are endpoint protection tools such as antivirus or EDR installed and maintained on all business devices?	☐	☐	☐	
D03.07	Is there a defined process for applying security patches within a documented timeframe?	☐	☐	☐	
DOMAIN 03 SCORE _____ / 14 Rating: _____					

DOMAIN 04 Data Protection		MAX 14 pts			
ID	Control	YES	PARTIAL	NO	Notes
D04.01	Have you identified and documented the sensitive data types your business collects, stores, or transmits?	☐	☐	☐	
D04.02	Is sensitive data encrypted at rest on servers, workstations, and portable devices?	☐	☐	☐	
D04.03	Is sensitive data encrypted in transit using HTTPS, TLS, or encrypted email?	☐	☐	☐	
D04.04	Are business backups performed regularly, stored in at least two locations including one offsite, and tested?	☐	☐	☐	
D04.05	Is there a documented data retention and disposal policy? Are devices securely wiped at end of life?	☐	☐	☐	
D04.06	Do you know which third-party vendors have access to your sensitive data and have you reviewed their security?	☐	☐	☐	
D04.07	Is access to sensitive data logged and are those logs reviewed periodically for anomalies?	☐	☐	☐	
DOMAIN 04 SCORE _____ / 14 Rating: _____					

DOMAIN 05 Incident Response		MAX 12 pts			
ID	Control	YES	PARTIAL	NO	Notes
D05.01	Does your organization have a documented Incident Response Plan?	☐	☐	☐	
D05.02	Has the Incident Response Plan been reviewed or tested in a tabletop exercise in the past 12 months?	☐	☐	☐	
D05.03	Do all staff know who to contact internally and externally if they suspect a security incident?	☐	☐	☐	
D05.04	Do you have cyber liability insurance covering data breach response, notification, and legal expenses?	☐	☐	☐	

D05.05	Is there a process for preserving evidence during a security incident without contaminating it?	☐	☐	☐	
D05.06	Have you identified your regulatory or legal notification obligations in the event of a data breach?	☐	☐	☐	
DOMAIN 05 SCORE _____ / 12 Rating: _____					

DOMAIN 06 Vendor and Third-Party Risk		MAX 12 pts			
ID	Control	YES	PARTIAL	NO	Notes
D06.01	Do you maintain an inventory of all third-party vendors, contractors, and SaaS tools with access to your systems?	☐	☐	☐	
D06.02	Are vendor security practices reviewed before onboarding through SOC 2 reports or security questionnaires?	☐	☐	☐	
D06.03	Do vendor contracts include security requirements, data handling obligations, and breach notification clauses?	☐	☐	☐	
D06.04	Is vendor access to your systems limited to what is necessary and monitored while active?	☐	☐	☐	
D06.05	Is there a process for reviewing and revoking vendor access when a contract ends?	☐	☐	☐	
D06.06	Are critical business functions dependent on a single vendor without a documented contingency plan?	☐	☐	☐	
DOMAIN 06 SCORE _____ / 12 Rating: _____					

DOMAIN 07 Security Awareness		MAX 14 pts			
ID	Control	YES	PARTIAL	NO	Notes
D07.01	Do all employees receive security awareness training at least annually?	☐	☐	☐	
D07.02	Have employees been trained to recognize and report phishing emails and social engineering attempts?	☐	☐	☐	
D07.03	Is there a clear, low-friction process for employees to report suspected phishing without fear of blame?	☐	☐	☐	
D07.04	Do you conduct phishing simulations or tests to measure and improve employee awareness?	☐	☐	☐	
D07.05	Are new employees required to complete security awareness training as part of onboarding?	☐	☐	☐	

D07.06	Are employees aware of and trained on your AUP, password policy, and data handling policies?	☐	☐	☐	
D07.07	Is security awareness tailored to specific high-risk roles such as finance staff and IT administrators?	☐	☐	☐	
DOMAIN 07 SCORE _____ / 14 Rating: _____					

DOMAIN 08 Cloud and Remote Work		MAX 12 pts			
ID	Control	YES	PARTIAL	NO	Notes
D08.01	Are all cloud services inventoried and managed under a central IT or security review?	☐	☐	☐	
D08.02	Is MFA enforced at the tenant level on all cloud platforms including administrative accounts?	☐	☐	☐	
D08.03	Are employees required to use a company-approved VPN or zero-trust solution for remote access?	☐	☐	☐	
D08.04	Is there a BYOD policy requiring MDM enrollment for personal devices used for business?	☐	☐	☐	
D08.05	Are cloud storage platforms configured to prevent unauthorized external sharing of sensitive data?	☐	☐	☐	
D08.06	Is there a defined process for offboarding remote workers including revoking all cloud access?	☐	☐	☐	
DOMAIN 08 SCORE _____ / 12 Rating: _____					

// AI DISCLOSURE Developed with assistance from Claude (Anthropic). Reviewed and validated by Paul Green, CISSP.